

REPORTE COMPLETO Y EXHAUSTIVO

Ecosistema pomaire360.cl

Analisis SEO, Seguridad, Cumplimiento Legal Chileno y Tecnico

Fecha: 19 de August de 2026
Preparado por: Kiro (AI Development Assistant)
Cliente: Pomaire 360 / Diego Ignacio Rojas Barros

ARQUITECTURA DEL ECOSISTEMA

- 1. www.pomaire360.cl (Pomaire-360) - HTML estatico + JS vanilla - Guia turistica principal
- 2. comprayvende.pomaire360.cl (pomaire360) - Vercel Serverless + Upstash Redis - Backend API
- 3. app.pomaire360.cl (pomaire360-app) - Next.js 14 + Supabase - App con directorio y resenas

RESUMEN EJECUTIVO

- Total de problemas detectados: 16
- Criticos (Semana 1): 4
 - Importantes (Semana 2): 6
 - Moderados (Semana 3+): 6
 - Puntos positivos destacados: 15

PROBLEMAS CRITICOS (Accion inmediata)

[!] 1. CONFLICTO DE REDIRECTS vs PAGINAS EXISTENTES

Afecta: www.pomaire360.cl | **Severidad:** ALTA | **Impacto:** SEO

El archivo _redirects define redirecciones 301 PERO las paginas originales siguen existiendo como archivos HTML Y siguen en el sistema i18n generando versiones EN/PT:

```
/gastronomia/ -> /restaurantes/ (archivo gastronomia/index.html EXISTE)
/alojamientos/ -> /alojamiento/ (archivo alojamientos/index.html EXISTE)
/alrededores/ -> /turismo/ (archivo alrededores/index.html EXISTE)
/que-ver/ -> /turismo/ (archivo que-ver/index.html EXISTE)
/locomocion/ -> /transporte/ (archivo locomocion/index.html EXISTE)
/gruas/ -> /transporte/ (archivo gruas/index.html EXISTE)
```

Consecuencias:

- Google indexa ambas URLs -> contenido duplicado
- Hreflang de paginas deprecated apuntan a versiones EN/PT que dan 404
- Dependiendo del CDN, la redirect puede no dispararse si el archivo existe

Solucion: Eliminar archivos HTML deprecated y sacarlos del page-map.js

[!] 2. CSRF BYPASS EN API PUBLICA

Afecta: comprayvende.pomaire360.cl | **Severidad:** ALTA | **Impacto:** Seguridad

En _utils.js, la funcion verifyOrigin() permite peticiones sin header Origin:

```
function verifyOrigin(req) {
  if (!origin) { return true; } // BYPASS
}
```

Cualquier script/bot puede hacer POST a /api/negocios y /api/mensajes.
La unica defensa es rate limit por IP que se puede evadir con IPs rotativas.

Solucion: Solo permitir sin Origin si viene con admin token.

[!] 3. HREFLANG APUNTANDO A PAGINAS INEXISTENTES

Afecta: www.pomaire360.cl | **Severidad:** ALTA | **Impacto:** SEO

Varias paginas declaran hreflang en/pt pero NO tienen versiones generadas:

- /restaurantes/ - declara hreflang EN/PT pero no existe en EN ni PT
- /transporte/ - declara hreflang EN/PT pero no existe en EN ni PT
- /turismo/ - declara hreflang EN/PT pero no existe en EN ni PT
- /talleres/ - declara hreflang EN/PT pero no existe en EN ni PT

- /banos/ - declara hreflang EN/PT pero no existe en EN ni PT

Solucion: Agregar al page-map.js o eliminar hreflang de esas paginas.

[!] 4. DATOS DE CONTACTO EXPUESTOS SIN PROTECCION

Afecta: comprayvende.pomaire360.cl | **Severidad:** ALTA | **Impacto:** Legal (Ley 21.719)

GET /api/negocios devuelve TODOS los negocios con telefono, WhatsApp, Instagram sin rate limiting en el GET, sin CAPTCHA ni proteccion anti-scraping.
Un scraper puede recopilar todos los telefonos en una sola peticion.

Solucion: Rate limiting en GET + documentar en politica de privacidad.

PROBLEMAS IMPORTANTES (Resolver pronto)

[!] 5. SIN CONTENT SECURITY POLICY EN APP Y BACKEND

Afecta: `app.pomaire360.cl` y `comprayvende.pomaire360.cl`

Ambos repos tienen headers de seguridad pero NO incluyen CSP.

Sin CSP, un XSS exitoso puede cargar scripts externos sin restriccion.

[!] 6. APP SIN SITEMAP NI ROBOTS.TXT

Afecta: `app.pomaire360.cl`

No tiene `sitemap.xml`, `robots.txt`, ni JSON-LD (structured data).

Google no puede descubrir los perfiles de negocios dinamicos.

[!] 7. APP SIN OG IMAGE POR DEFECTO

Afecta: `app.pomaire360.cl`

El `layout.tsx` tiene metadata OpenGraph pero sin propiedad `images`.

Compartir `homepage/planes` en redes sociales muestra tarjeta sin imagen.

[!] 8. INCONSISTENCIA DE CATEGORIAS ENTRE SISTEMAS

API POST usa slugs: `alfareria`, `talleres`, `restaurantes`...

API PUT (moderar) usa display names: `Artesania en greda`, `Comida y cocinera`...

Esto causa que la validacion de categorias sea inconsistente.

[!] 9. COOKIE CONSENT FALTANTE EN 2 PAGINAS

`/mapa-ilustrado/` y `/mapa-turistico/` no cargan `cookie-consent.js`.

[!] 10. PAGINAS LEGALES SIN OG TAGS NI HREFLANG

`/terminos/` y `/privacidad/` carecen de Open Graph tags y hreflang.

PROBLEMAS MODERADOS

[~] 11. Rate limit bypass si Redis cae (upload.js)

Si Redis esta caido, las subidas de imagenes pasan sin rate limiting.

[~] 12. Sin rate limiting en resenas (pomaire360-app)

Formulario de resenas permite envios ilimitados. Sin CAPTCHA ni debounce.

[~] 13. Admin URL publica en robots.txt

Disallow: /admin.html revela la existencia de la pagina admin.

[~] 14. Operaciones admin desde cliente (pomaire360-app)

negocios-table.tsx hace updates directos a Supabase desde el navegador.
Seguridad depende enteramente de RLS de Supabase.

[~] 15. Privacidad de la app desactualizada

Politica dice "enero 2025" vs "agosto 2026" del sitio principal.
No menciona Google OAuth ni Supabase como procesadores.

[~] 16. Header X-XSS-Protection deprecado

Los 3 repos incluyen X-XSS-Protection: 1; mode=block (deprecated).

PUNTOS POSITIVOS DESTACABLES

1. JSON-LD con @graph de 7 tipos - excepcional para SEO
2. Timing-safe token comparison en backend - previene timing attacks
3. CORS con allowlist explícita (no wildcard) en todos los endpoints
4. Cookie consent que realmente bloquea GA4 si rechazas + botón revocación
5. Prevención de Open Redirect en auth callback con allowlist
6. Defense-in-depth: admin verificado en middleware + layout + RLS
7. PWA/Service Worker con fallback por idioma para emergencias offline
8. Sanitización HTML robusta: escapeHTML, sanitizeTranslationHTML, sanitizeURL
9. Cumplimiento total Ley 19.496 y 21.719 en sitio principal
10. Performance: Critical CSS inline, fonts preloaded, lazy loading, defer
11. HSTS Preload con max-age 1 año + includeSubDomains
12. Skip-to-content, focus trap, prefers-reduced-motion, ARIA labels
13. Headers de seguridad completos en los 3 repositorios
14. Magic byte verification en uploads - previene archivos disfrazados
15. i18n con 21 páginas en 3 idiomas + hreflang bidireccional en sitemap

PLAN DE ACCION PRIORIZADO

Semana 1 (Urgente)

1. Resolver conflicto _redirects vs paginas existentes
2. Fix CSRF bypass en verifyOrigin() del backend
3. Corregir hreflang que apuntan a 404s
4. Agregar cookie-consent.js a mapa-ilustrado y mapa-turistico

Semana 2 (Importante)

5. Agregar CSP a pomaire360-app y pomaire360 backend
6. Implementar sitemap dinamico en app Next.js
7. Agregar OG image default en app layout
8. Agregar rate limiting al GET /api/negocios

Semana 3 (Mejora)

9. Actualizar politica de privacidad de la app
10. Implementar JSON-LD LocalBusiness en paginas de negocios
11. Corregir inconsistencia de categorias en PUT /api/moderar
12. Agregar rate limiting a formulario de resenas

Backlog

13. Eliminar header X-XSS-Protection o establecer en 0
14. Agregar robots.txt a la app
15. Mejorar robots.txt del backend (no revelar /admin.html)
16. Agregar paginas nuevas al page-map i18n
17. Verificar politicas RLS de Supabase

CALIFICACIONES POR DOMINIO

www.pomaire360.cl (Sitio Principal)

SEO On-Page: ***** Excelente
SEO Tecnico: **** Muy Bueno (3 issues: redirects, hreflang)
Seguridad: ***** Excelente
Legal: ***** Cumple totalmente
Accesibilidad: ***** Excelente
Performance: ***** Excelente
Cookies: **** Muy Bueno (2 paginas sin banner)

comprayvende.pomaire360.cl (Backend API)

Seguridad API: **** Bueno (2 issues: CSRF, rate limit)
Proteccion Datos: *** Regular (contactos sin proteccion)
Legal: *** Regular (sin politica propia)
Input Validation: ***** Excelente
Autenticacion: ***** Excelente (timing-safe, fail-closed)

app.pomaire360.cl (App Next.js)

SEO: *** Regular (sin sitemap, JSON-LD, OG image)
Seguridad: ***** Bueno (sin CSP, sin rate limit resenas)
Legal: *** Regular (privacidad desactualizada)
Auth/Access: ***** Excelente
UX/Performance: ***** Excelente

--- Fin del reporte ---

Generado: 2026-08-19 19:14 UTC
Herramienta: Kiro AI Development Assistant
Repositorios analizados: DIRB92/Pomaire-360, DIRB92/pomaire360, DIRB92/pomaire360-app